

Vendor Risk Management Policy

Third-party assurance

OWNER	Security & GRC
EFFECTIVE	2026-07-13
REVIEW CYCLE	Annual or material change
CLASSIFICATION	Internal

1. Purpose and scope

This policy establishes how Cobalt Harbor Systems ensures that vendors are risk-tiered before onboarding and monitored when services or data uses change. It applies to personnel and approved providers performing the governed activity.

2. Control objectives

Objective A. Establish accountable, repeatable operating decisions for third-party assurance.

Objective B. Produce evidence that supports independent assurance and timely remediation.

3. Required operating practices

1. Plan the activity with documented scope, owner, and timing appropriate to third-party assurance.
2. Execute and record the activity using the required evidence attributes: service description, data profile, due diligence, contract safeguards, and monitoring decision.
3. Review exceptions and changes before they affect the control conclusion.
4. Preserve decisions and evidence in the approved repository for the stated retention period.

4. Accountability

ROLE	RESPONSIBILITY
Business sponsor	Carries the assigned decision, review, or recordkeeping responsibility.
Procurement	Carries the assigned decision, review, or recordkeeping responsibility.
Vendor risk lead	Carries the assigned decision, review, or recordkeeping responsibility.

Third-party assurance: assurance criteria

5. Evidence standard

The accountable owner retains evidence that is sufficient to demonstrate the operating result. At minimum, each record includes: service description, data profile, due diligence, contract safeguards, and monitoring decision. Evidence is linked to the applicable system, review period, owner, and disposition so another qualified reviewer can reproduce the conclusion.

6. Measurement and reporting

MEASURE	OPERATING THRESHOLD
Primary metric	High-risk vendors reassessed annually and before material service expansion
Quality review	Evidence completeness and sampled accuracy are reviewed monthly.
Management reporting	Trends, overdue actions, and material exceptions are reported to Security & GRC.

7. Noncompliance and escalation

A vendor without required safeguards cannot process regulated or sensitive data The responsible owner documents the correction, root cause, and follow-up verification. Material deviations are included in the assurance register until closure.

8. Revision and approval

The policy owner reviews this policy annually, after a material control change, or following an assurance finding related to third-party assurance. Revisions must identify changed obligations, affected owners, and implementation timing before approval.

APPROVER	ROLE	STATUS
Mira Patel	Director, Security & GRC	Approved
Jonah Reed	Control Assurance Lead	Reviewed